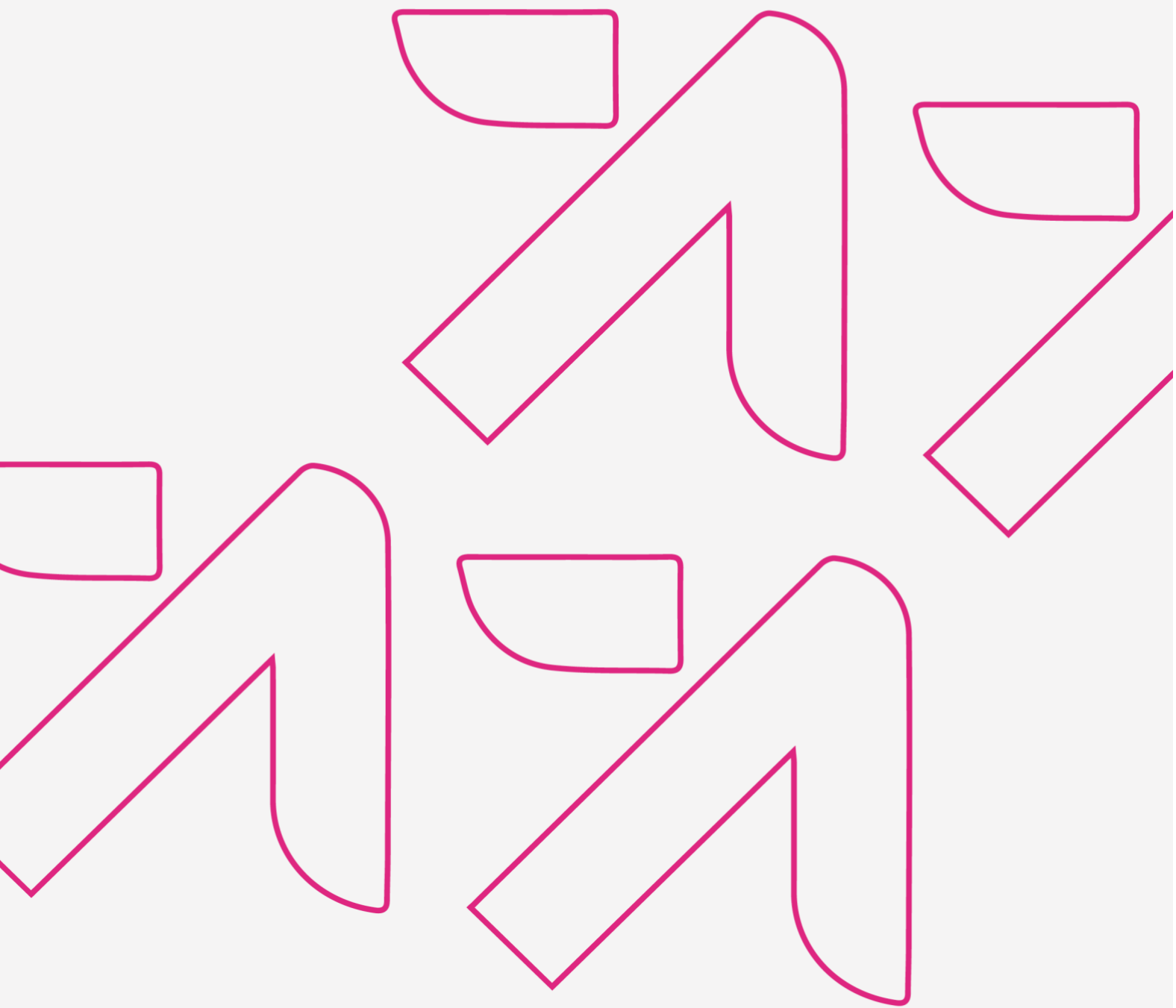




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT10. Respuesta y recuperación ante incidentes

Encaje en el curso 2026/2027: esta unidad cierra el RA7 (tema 13: copias de seguridad y recuperación). La respuesta a incidentes se trabaja a fondo en el módulo de Incidentes de ciberseguridad (5021); aquí se ve desde el punto de vista del bastionado.

1. Objetivo de la respuesta a incidentes

La respuesta a incidentes (IR) busca **detener, contener y mitigar** cualquier incidente de seguridad para reducir su impacto en la organización. El objetivo no es “evitar que pase” (eso lo hacen las UT anteriores), sino **gestionar correctamente cuando ya ha ocurrido**.

Un incidente mal gestionado puede amplificar el daño, provocar pérdida de datos, afectar la continuidad del negocio y empeorar la exposición pública.

2. Concepto de incidente de seguridad

Un incidente es cualquier evento que:

- compromete la confidencialidad, integridad o disponibilidad;
- afecta sistemas, datos o servicios críticos;
- implica acceso no autorizado, malware, fuga de información o interrupción.

Ejemplos: ransomware, explotación de vulnerabilidades, filtración de credenciales, cambios no autorizados, denegación de servicio, intrusiones internas.

3. Fases clásicas de respuesta a incidentes

Las fases que siguen son las del modelo clásico de NIST (SP 800-61) y SANS, que es el que encontrarás en la mayoría de planes. La revisión 3 de la SP 800-61 (2025) lo reorganiza según las funciones del NIST CSF 2.0 (gobernar, identificar, proteger, detectar, responder y recuperar), pero las tareas son las mismas.

3.1. Preparación

Todo arranca antes del incidente:

- Equipos designados
- Playbooks/documentación
- Inventario actualizado
- Roles claros
- Copias de seguridad verificadas
- Herramientas listas (EDR, SIEM, forense)

Sin preparación, las siguientes fases quedan cojas.

3.2. Detección

Identificación del incidente mediante:

- Alertas
- Logs
- SIEM
- Análisis de anomalías
- Notificaciones internas o externas

El reto es detectar rápido, no cuando ya es tarde.

3.3. Análisis

Confirmar que el evento es real:

- Qué sistemas están afectados
- Cómo entró el atacante
- Qué técnica utilizó
- Qué alcance tiene
- Qué impacto ha generado o puede generar

Aquí se decide la gravedad del incidente.

3.4. Contención

Acciones inmediatas para frenar al atacante o **detener** el daño:

- Aislar sistemas afectados
- Deshabilitar cuentas comprometidas
- Bloquear conexiones maliciosas
- Forzar cambios de credenciales
- Desplegar reglas temporales de firewall

La contención puede ser:

- **Corta duración:** frena rápidamente
- **Larga duración:** estabiliza mientras se investiga

3.5. Erradicación

Una vez controlado:

- Eliminar malware
- Cerrar vulnerabilidades explotadas
- Quitar puertas traseras

- Reinstalar sistemas comprometidos
- Revisar configuraciones inseguras
- Confirmar que el atacante no sigue dentro

3.6. Recuperación

Restaurar la operación normal:

- Recuperar sistemas desde backups limpios
- Verificar integridad
- Parchar antes de volver a producción
- Reintroducir servicios de forma gradual
- Monitorización reforzada tras recuperación

3.7. Lecciones aprendidas

La fase que siempre se salta y es la más útil:

- Documentación completa
- Identificar fallos de procedimiento o configuraciones
- Revisar políticas
- Fortalecer controles
- Actualizar playbooks

Objetivo: que el mismo incidente no ocurra dos veces.

4. Indicadores de compromiso (IoC)

Son evidencias que indican que un sistema puede estar comprometido:

- IPs o dominios maliciosos
- Hashes de malware
- Procesos anómalos
- Cambios no autorizados
- Conexiones internas inesperadas
- Creación de usuarios sospechosos
- Eventos repetidos de autenticación fallida
- Logs borrados o manipulados

Estos IoC guían la investigación técnica.

5. Herramientas y técnicas de respuesta

5.1. EDR y herramientas de endpoint

- Aislamiento remoto
- Eliminación de malware
- Revisión de procesos
- Alertas basadas en comportamiento

5.2. Forense

- Captura de memoria
- Análisis de disco
- Timeline de eventos
- Extracción de artefactos (prefetch, logs, registros)

5.3. SIEM

- Correlación de eventos
- Detección de cadenas de ataque
- Alertas de seguimiento

5.4. Redes

- PCAPs
- Análisis de tráfico
- Bloqueos en firewall
- Trazabilidad de conexiones

6. Gestión de comunicaciones

Un aspecto crítico:

- Comunicación con dirección
- Comunicación con equipos técnicos
- Comunicación con clientes (si procede)
- Comunicación con organismos (ver plazos más abajo)

Plazos de notificación que hay que conocer

- **AEPD:** si hay brecha de datos personales, notificación en un máximo de 72 horas desde que se conoce (art. 33 del RGPD).
- **CSIRT de referencia:** INCIBE-CERT para empresas y ciudadanía; CCN-CERT para el sector público y los sistemas dentro del ENS.

- **NIS2:** las entidades esenciales e importantes deben dar una alerta temprana en 24 horas, una notificación en 72 horas y un informe final en un mes. Comprueba el estado de su transposición en España en el momento de aplicarla.
- Comunicación con proveedores y terceros

La comunicación mal gestionada empeora la crisis tanto como el incidente en sí.

7. Continuidad de negocio y resiliencia

Un incidente puede **detener** un servicio crítico. El plan de continuidad define:

- Servicios esenciales
- Tiempos máximos de interrupción (RTO)
- Máxima pérdida de datos aceptable (RPO)
- Recursos alternativos
- Procedimientos de contingencia

Una organización preparada no deja de operar aunque sufra un ataque.

8. Copias de seguridad y restauración

8.1. Requisitos de backups

- Regla 3-2-1: tres copias, en dos soportes distintos, una fuera de la sede
- Versionado
- Copias offline u offsite
- Pruebas periódicas de restauración
- No accesibles desde la red principal (para evitar ransomware)
- Al menos una copia inmutable o desconectada: es lo primero que busca cifrar o borrar un atacante

8.2. Restauración segura

Restaurar solo desde backups **verificados y limpios**. Evitar reintroducir malware por accidente.

9. Integración con bastionado y arquitectura

La respuesta a incidentes depende directamente de:

- Segmentación adecuada
- Registros bien implementados
- Servicios bastionados
- IAM correctamente aplicado

- Parches al día
- Controles defensivos sólidos

Si las UT anteriores se aplican bien, esta unidad se vuelve mucho más eficiente.

10. Buenas prácticas finales

- Preparación constante
- Playbooks claros, realistas y probados
- Zero Trust aplicado también a la respuesta
- Copias de seguridad verificadas
- Detección temprana mediante monitorización adecuada
- Comunicación interna bien gestionada
- Documentación detallada
- Revisión profunda después del incidente
- Mejoras continuas: nunca quedarse igual tras un ataque

Para ampliar

- NIST SP 800-61: guía de gestión de incidentes.
- Guía Nacional de Notificación y Gestión de Ciberincidentes (INCIBE-CERT / CCN-CERT).
- Guía CCN-STIC 817: gestión de ciberincidentes en el ENS.
- AEPD: guía para la notificación de brechas de datos personales.